

Identity, encryption, detection

Day 5 - Morning

Running scenario: Thara Hospitals patient portal pilot

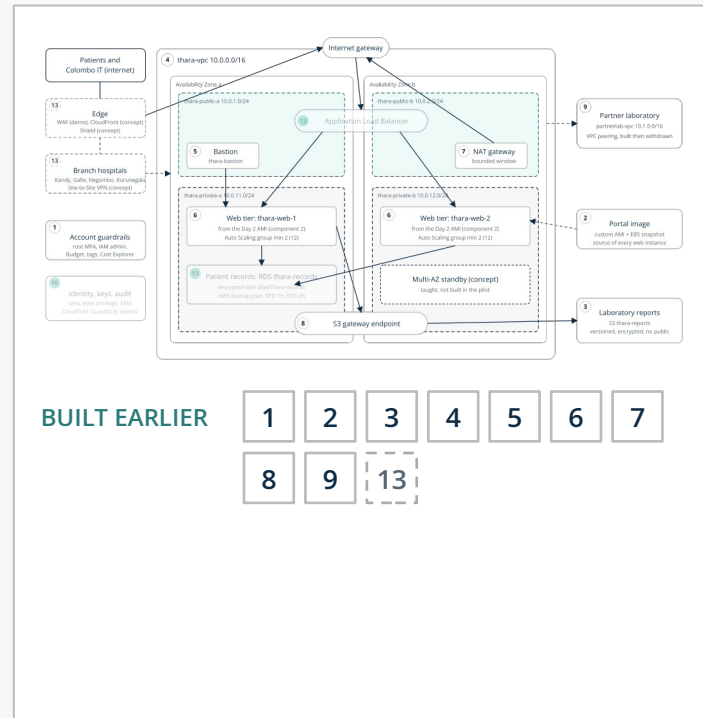
Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management



Today

Who can read patient data, what protects it, and how would we know?

- Identity is the perimeter - 40 min
- Encrypting what the hospital holds - 30 min
- Knowing when something happened - 30 min



CONCEPT 1

Identity is the perimeter

The Day 2 key, the contractor with two days, and the DPO's "who".

40 min

Who is asking, and two kinds of policy

Identity-based

Attached to

A user, a group or a role.

Answers

What may this identity do?

Today

The web tier's policy.

Resource-based

Attached to

A resource: a bucket, a key, a role's trust.

Answers

Who may do what to this resource?

Today

A key policy and a trust policy.

Every request has a principal: a user, a role or a service.

The anatomy of a statement

- **Effect:** Allow or Deny. There is no third value
- **Action:** a service and an operation. A star is a wildcard
- **Resource:** what it may be done to, as an ARN
- A resource-based policy adds a **Principal:** who it is talking about

YOU ALREADY KNOW THIS

RBAC on a firewall manager; the enable password nobody should share.

How AWS decides

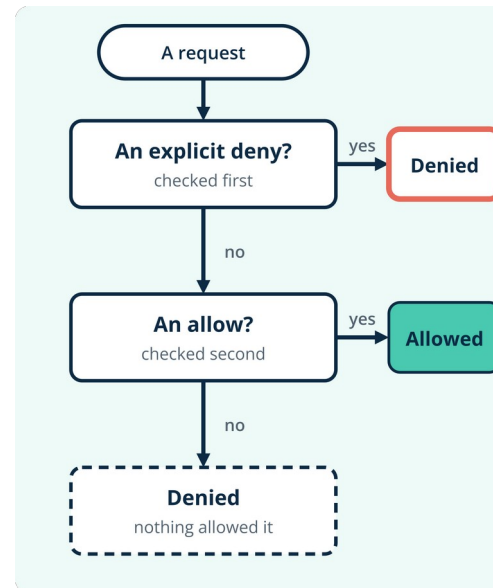
1. An **explicit deny** that matches? The answer is no
2. If not, an **allow** that matches? The answer is yes
3. If neither: no. This is the **implicit deny**

The policy simulator runs this for you, before anything is attached.

COMMON MISTAKE

An explicit allow wins.

An explicit deny always wins.



Two ways to be refused. Only one is cured by an allow.

Least privilege: a method, not a slogan

1. Start from the action the workload needs
2. Name the actions. Two, not `s3:*`
3. Name the resources. One bucket and its objects
4. Write it, test it in the simulator, then attach it



THARA HOSPITALS

The web tier lists one bucket and reads its reports. Nothing else.

Roles: credentials that expire

- A user has a password or a key of its own. A **role** has neither
- A role is **assumed**. Its trust policy says by whom
- It issues **temporary credentials** that expire by themselves
- An **instance profile** hands a role to an instance

The cure for long-lived keys. You met one on Day 3, behind the flow log.

The rest is discipline



SIGN-IN

MFA

On every identity that a person uses.
A stolen password is then not enough.

KEYS

Key hygiene

No key on root. No key in a file, a screenshot or a repository. Delete it when its job ends.

Deactivated is not deleted.

ACCOUNTS

Organizations

Many accounts, one bill, and one policy boundary that no account beneath can exceed.

A concept today.



DATA PROTECTION OFFICER

Who can read patient data? I do not want a list of who should. I want to know who can, today, and I want you to show me where it says so.

The Data Protection Officer, on the key that has been on the web server since Day 2.

CONCEPT 2

Encrypting what the hospital holds

Special-category data. Encryption is an acceptance criterion.

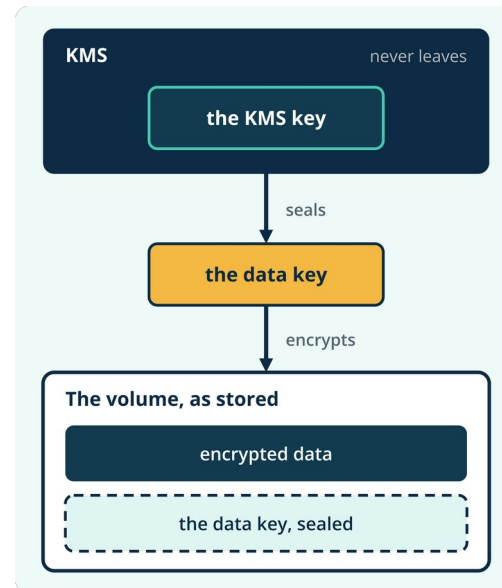
30 min

Encryption at rest, and the envelope

- **KMS** holds keys and never gives one out
- A **customer-managed key** is yours: its policy, its lifetime
- A **data key** encrypts the data. The KMS key seals the data key
- The sealed data key is stored beside the data

YOU ALREADY KNOW THIS

Full-disk encryption on a laptop with the key held by the domain.



Stolen storage holds encrypted data and a sealed key.

Defaults, and the wire

- **S3** encrypts every new object without being asked
- **EBS** encrypts a volume when you ask, at creation
- A volume made from an unencrypted snapshot can be encrypted as it is made
- **In transit** is TLS, terminated at the load balancer on Day 7



THARA HOSPITALS

Patient records and report PDFs are special-category data.

Two questions, two policies

- Who can read the bucket? The policies on the principal and the bucket
- Who can use the key? The **key policy**
- Under a customer-managed key, a principal needs a yes to both

The people who run storage and the people who hold the key need not be the same.

COMMON MISTAKE

Encrypting the bucket means only the owner can read it.

Encryption and access control are separate questions.

CONCEPT 3

Knowing when something happened

The DPO's "how would we know".

30 min

Three readers



THE API

CloudTrail

Every console click and CLI call is an event. Who, when, from where, what.

Records. Judges nothing.

TELEMETRY

GuardDuty

Reads flow logs, DNS lookups and CloudTrail events, and looks for trouble.

Findings, not alerts.

POLICIES

IAM Access Analyzer

Reads resource policies. Reports what is reachable from outside the account.

An open door, used or not.

None of the three blocks anything.

The edge, and a checklist

- **WAF** and **Shield** stand at the edge, as component 13
- WAF is the one that blocks. It is demonstrated on Day 7
- The security pillar of the Well-Architected Framework is the checklist
- Identity, detection, infrastructure, data, incident response

YOU ALREADY KNOW THIS

Syslog from every device to a SIEM; an IDS on a span port.

COMMON MISTAKE

GuardDuty blocks attacks.

It reports findings. A person must act.

Demonstration: Simulate, flag, trace



1. In the policy simulator, test a read-only bucket policy against GetObject, PutObject and ListBucket
2. A bucket with Block Public Access off and a public policy: the Access Analyzer finding. Then close it again
3. Change a security group rule. Find the event in CloudTrail: user, time, source address

Predict each result before it appears. This afternoon the predictions are yours.

Activity: the threat walk, 35 minutes



1. In pairs, walk the Thara environment as built, with the security pillar's questions
2. Four seeds. For each: what it allows an attacker to do, and which control closes it
3. Add two threats of your own
4. This table is the start of the capstone threat table

The threat table

4

seeds given to you
one row each

2

threats of your own
exact: which data, which path

6

rows for each pair
the capstone needs eight

Seed	What it allows	The control that closes it
A stolen access key		
An open security group		
A public bucket		
A missing audit trail		

Common mistakes



COMMON MISTAKE

An explicit allow wins.

An explicit deny always wins.

COMMON MISTAKE

Encrypting the bucket means only the owner can read it.

Encryption and access control are separate questions.

COMMON MISTAKE

GuardDuty blocks attacks.

It reports findings.

Before the next session



READ

Shields, AWS Security

Chapters 7 and 8: protecting data; logging and audit trails.

SELF-CHECK

CLF-C02 bank

Domain 2 set B, 15 items.

PRACTICE

PQ5

A security control set for a stated threat list, with justification.

Evidence Pack 5 follows this afternoon's lab.

Questions & Discussion



Next: this afternoon the key goes, and component 10 is built.



Disclaimer & Copyright



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While I strive to keep the information accurate and up-to-date, I make no representations or warranties of any kind, express or implied, about the completeness, accuracy, reliability, suitability, or availability of the content within this presentation.

Cloud services, prices and free-tier terms change. Figures in this presentation were correct when prepared; check the provider's current documentation before relying on them.

This presentation may include references or links to third-party websites or content. I do not endorse the views expressed or the information provided on such external sites, and I am not responsible for their content.

Thara Hospitals (Pvt) Ltd is a fictional organisation created for teaching. AWS and Amazon Web Services are trademarks of Amazon.com, Inc. or its affiliates; this material is not affiliated with or endorsed by AWS.



© 2026 Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content licensed under CC BY-NC-SA 4.0. Images and artworks used for explanation may contain third-party material used under fair dealing for education.

Revision f6540a2